

AiLernova — Bug Audit

React Native / Expo SDK 54 client & Express + Postgres backend

29 July 2026 · branch `main` @ `e7543bb` · 22 findings

Scope reviewed. Authentication, navigation and app-wide state; the API/axios layer; the four test & quiz engines; the server's routes, middleware, controllers and scoring services; and the uncommitted working change to `SessionsScreen.js`.

Not reviewed. The ~400 static content files under `src/data/` and `src/notes/`, and the Brain Gym / teacher-avatar / parent-app screens.

Headline. Three separate timed-test screens share the same stale-closure defect, so running out of time discards the student's answers. Phone/OTP sign-in cannot work at all. Online tests have no class-level authorization.

4

CRITICAL

4

HIGH

8

MEDIUM

6

LOW

Critical — silent data loss & broken sign-in

C-01

CRITICAL

Time-up auto-submit sends an empty answer sheet

`src/screens/TestQuestionScreen.js:112-118, 141`

```
useEffect(() => {
  timerRef.current = setInterval(() => {
    setRemaining((r) => { if (r <= 1) { clearInterval(...); handleSubmit(true); return 0; }
    return r - 1; });
  }, 1000);
  return () => clearInterval(timerRef.current);
}, []); // ← empty deps
```

`handleSubmit` is captured from the first render, where `answers` is `{}`. When the clock expires it fires `onSubmit({ answers: {}, answeredCount: 0, ... })`.

Impact: every answer the student gave is discarded on timeout. Manual submit is fine — only the timeout path is broken.

Fix: hold the latest `handleSubmit` in a ref (as `OnlineTestScreen`'s `Runner` already does) and call `submitRef.current()` from the interval.

C-02**CRITICAL****Mock-test timeout writes a zero-score attempt to the database**`src/screens/McqTestScreen.js:91-101, 163-173`

Same defect. The interval closes over the `doSubmit` from the render in which `phase` became `'quiz'`, so `persistAttempt` reads `answers`, `status` and `secs` at their initial values and posts `answers: {}`, `timeTakenSec: 0`.

Impact: the results screen shows the correct score (it recomputes fresh on render), but the server records 0/N. `submittedRef` then blocks any later correction — the two diverge permanently.

Fix: same ref indirection as C-01, applied to `doSubmit`.

C-03**CRITICAL****Answered questions scored as "skipped" when the timer expires**`src/screens/McqQuizScreen.js:87-98, 127-136`

`reveal()` is captured when the question loads, so its `selected` is always `null`. Selecting an option and letting the countdown run out records the question as skipped rather than correct or wrong.

Impact: understated scores and corrupted per-question accuracy feeding the progress dashboard.

Fix: read `selected` from a ref inside `reveal()`, or add it to the effect's dependency list.

C-04**CRITICAL****Phone/OTP sign-in is mocked and traps the user in a logout loop**`src/api/authApi.js:3, 51-64 · src/utils/storage.js:17-31 · server/src/routes/auth.js:60-64`

`MOCK_MODE = true` makes `verifyOTP` accept the literal code `123456` and return `token: 'mock-jwt-token-12345'`. `getToken()` deliberately strips exactly that token on read, so every subsequent request goes out unauthenticated → 401 → `onUnauthorized()` wipes the session → back to the login screen.

Flipping the flag will not help: no `/api/auth/send-otp`, `/verify-otp` or `/complete-phone-signup` route exists on the server.

Impact: the Phone tab is presented as a working option on both `LoginScreen` and `SignupScreen`, and cannot sign anyone in.

Fix: either implement the three server routes (MSG91 config already exists in `config/env.js`) or hide the Phone tab until it ships.

High

H-01 HIGH Online tests have no class or subject authorization

server/src/controllers/onlineTest.controller.js:9-12, 28-34

```
const classOf = (req) => {
  const m = String(req.query.class || '').match(/d{1,2}/) // any user, not just testers
  return m ? parseInt(m[0], 10) : resolveClassNum(req)
}
```

Two problems. First, `?class=` is honoured for every caller — the whole point of `resolveClassNum` is that only allowlisted tester accounts may override their class. Second, `GET /online-tests/test/:testId` performs no scope check at all, and the response payload includes `correctOptionId` for every question.

Impact: any authenticated student can enumerate ids and pull any class's tests together with the answer key.

Fix: mirror `mockTest.controller.assertTestInScope` — resolve the class via `resolveClassNum` only, and verify the test's `class_level` before returning it.

H-02 HIGH Malformed test id returns 500 instead of 400/404

server/src/services/onlineTest.service.js:67

`BigInt(testId)` throws a `SyntaxError` on any non-numeric path segment. It is not an `AppError`, so `errorHandler` reports a generic *Internal server error*.

Fix: validate with a `parseId` helper like the mock-test controller's before calling the service.

H-03 HIGH CORS wildcard combined with credentials

server/src/config/env.js:119-123 · server/src/index.js:23-28

`origins` defaults to `'*'` while the middleware sets `credentials: true`. Browsers reject `Access-Control-Allow-Origin: *` on credentialed requests.

Impact: the admin web portal breaks unless `ALLOWED_ORIGINS` is set — and if it is left unset in production the API is also open to every origin.

Fix: require an explicit origin list in production; fail startup if it is missing.

H-04 HIGH uncaughtException is swallowed and the process keeps running

server/src/index.js:85-87

After an uncaught throw the process state is undefined — connection pool, open transactions and in-flight requests may all be inconsistent, yet the server keeps accepting traffic.

Fix: log, then `process.exit(1)` and let the supervisor restart. Keep the `unhandledRejection` handler as-is if pooler resets are the concern.

Medium

M-01 MEDIUM Password rules disagree between client and server

src/utils/validators.js:11 · src/screens/SignupScreen.js:127 · server/src/routes/auth.js:27

Client requires ≥ 6 characters and the placeholder reads "Password (min 6 characters)"; the server requires ≥ 8 . A 6- or 7-character password passes local validation, then fails after a round trip.

M-02 MEDIUM "Forgot password?" is a dead control

src/screens/LoginScreen.js:129-131

A `TouchableOpacity` with no `onPress`. Tapping does nothing, with no reset flow anywhere in the codebase.

M-03 MEDIUM Uncommitted SessionsScreen change makes two branches unreachable

src/screens/SessionsScreen.js:132-135, 156-168 (working tree, uncommitted)

```
const recordings = [...(sessions || []).filter((s) => !!s.recordingUrl), DUMMY_RECORDING];
const hasSessions = (sessions || []).length > 0 || recordings.length > 0;
```

`recordings` always contains `DUMMY_RECORDING`, so both conditions are permanently true.

Impact: the "No recordings yet" empty state added in the same change can never render; the "Live 1:1 classes are on the way" coming-soon hero is now unreachable, so a student with zero sessions sees a schedule page containing only a demo clip. The video also points at an external ailernova.in WordPress asset that would ship to production.

M-04 MEDIUM Sectioned mock test can crash on a malformed section map

src/screens/McqTestScreen.js:79-88, 428 · server/src/services/mockTest.service.js:83-95

`current` is driven by cumulative section counts. Because sections and questions are assembled independently on the server, counts that sum beyond `questions.length` leave `q = qs[current]` undefined and `q.question` throws during render.

Fix: clamp `current` to `qs.length - 1` and render an empty state when `q` is missing.

M-05 MEDIUM State updaters call setState (impure, double-invoked in StrictMode)

src/screens/McqTestScreen.js:95 · src/screens/McqQuizScreen.js:129-136

`doSubmit()` is called from inside a `setSecs` updater, and `setScore` from inside a `setSubmitted` updater. React double-invokes updaters in StrictMode, so the second invocation can double-count the score.

M-06 **MEDIUM** No double-submit guard in the online-test runner

src/screens/OnlineTestScreen.js:429-443, 254-263

Two quick taps on Submit fire `onFinish` twice, and `saveOnlineTestAttempt` increments the stored attempt count on each. `McqTestScreen` guards this with `submittedRef`; the online runner does not.

M-07 **MEDIUM** Tester class selection does not survive a reload

src/context/AuthContext.js:59, 125-127

Startup restores the persisted `@ailernova_class`, then an effect immediately overwrites it with `scope.className`. A tester who picked Class 9 is back on their profile class every launch.

M-08 **MEDIUM** Paged admin lists can append the same page twice

src/screens/admin/ui/usePagedList.js:18-41

`loadingMore` is set inside the async `load`, so two taps within the same render tick both pass the `!loadingMore` guard and append identical rows.

Low

ID	LOCATION	FINDING
L-01	results.service.js:214	<code>avgScore</code> divides <code>pctSum</code> (summed only over rows with <code>total > 0</code>) by <code>testsTaken</code> (all rows), diluting the average whenever a zero-total attempt exists.
L-02	mockTest.controller.js:50, 72, 85	Four sites branch on <code>err.status</code> , but <code>AppError</code> sets <code>statusCode</code> — dead code. Harmless today because <code>next(err)</code> handles it correctly.
L-03	RuntimeConfigContext.js:82-83	<code>lastFetch</code> is stamped before the request is made, so a failed fetch blocks any retry for the full 5-minute staleness window.
L-04	mockTest.service.js:168-174	A failed attempt <code>INSERT</code> is swallowed by an empty <code>catch</code> ; the student is shown a score that was never recorded.
L-05	admin/sessions.controller.js:73	<code>update</code> writes <code>mode</code> unvalidated, while <code>create</code> (line 59) coerces it to <code>online / offline</code> . A PATCH can persist an invalid value.
L-06	sessions.controller.js:22	<code>ORDER BY starts_at ASC</code> lists the oldest recordings first; the replay library reads newest-last.

Suggested order of work

- **C-01, C-02, C-03** are one defect in three places and share a single fix — a ref holding the latest submit/reveal callback. `OnlineTestScreen.js:409` already contains the working pattern to copy.
- **C-04** is a product decision: implement the OTP routes, or hide the Phone tab.
- **H-01** is the only finding with a security impact and is a contained change to one controller.
- **M-03** should be resolved before the working tree is committed.

Coverage caveat. This audit covers application and server logic only. The ~400 static content files under `src/data/` and `src/notes/`, and the Brain Gym, teacher-avatar and parent-app screens, were not reviewed. Findings were read directly from source; none were reproduced against a running build.